

# Architecture and review: the SRA, Well-Architected, and cost as a security signal

Closing Domain 6 – the account structure everything in this course has assumed, and how you review it.

Account structure is a **security control**. It is the only boundary that does not depend on a policy being correct.

# The AWS Security Reference Architecture

| OU AND ACCOUNT                      | HOLDS                                                                 |
|-------------------------------------|-----------------------------------------------------------------------|
| Org Management                      | Organizations, SCPs, RCPs, declarative policies. No workloads         |
| Security OU – Security Tooling      | Delegated admin for GuardDuty, Security Hub, Config, Detective, Macie |
| Security OU – Log Archive           | The immutable log destination. Read by few, written by services       |
| Infrastructure OU – Network         | Transit Gateway, Network Firewall, shared VPCs via RAM                |
| Infrastructure OU – Shared Services | Directory Service, common tooling, golden AMIs                        |
| Workloads OU – Application          | The actual workloads, one account per workload and environment        |

## ON THE EXAM

Security Tooling and Log Archive are separate accounts on purpose: the people who read findings should not administer the evidence.

# Why Security Tooling and Log Archive are separate

- ◆ The people who read findings should not administer the evidence.
- ◆ Log Archive holds the org trail, Config history and central logs – with **Object Lock** from module 29.
- ◆ Security Tooling holds the consoles analysts use daily.
- ◆ **Delegated administration** keeps security services out of the management account.
- ◆ One combined 'security' account collapses the separation.

## ON THE EXAM

Module 1's argument – evidence must survive the administrator – as an account boundary.

# The Well-Architected security pillar

- ◆ **Seven design principles**, from a strong identity foundation through to preparing for security events.
- ◆ **Keep people away from data** is the one to dwell on – it explains Session Manager, Athena over downloads, and masking.
- ◆ Areas: security foundations, IAM, detection, infrastructure protection, data protection, incident response, **application security**.
- ◆ **Older material lists six areas**. Application security was added later.
- ◆ It is a **question set**, not a control list. It asks how, not whether a box is ticked.

## ON THE EXAM

This exam's six domains map onto these areas. Not a coincidence.

# Reviewing: the tool and Trusted Advisor

- ◆ The **Well-Architected Tool** reviews a workload against a lens and produces **risk-rated findings** and an improvement plan.
- ◆ It **surfaces Trusted Advisor checks against best practices**, mapped to a **Pillar** such as security.
- ◆ **Trusted Advisor** covers cost, performance, security, fault tolerance, limits and operations. Full checks need Business or Enterprise Support.
- ◆ It is **opinionated and shallow** – it flags an open security group without judging whether that is wrong.
- ◆ It complements Security Hub CSPM rather than replacing it.

## ON THE EXAM

A Well-Architected review is a conversation with evidence attached.

# Cost as a security signal

- ◆ An unexplained compute bill is a security event until proven otherwise.
- ◆ **Cost Anomaly Detection** applies ML to your spending pattern, per service or per account.
- ◆ In a dormant account it is often **faster than any security control** – an unused Region suddenly has a bill.
- ◆ Correlate with **GuardDuty CryptoCurrency findings** and Runtime Monitoring. Cost says something happened; GuardDuty says what.
- ◆ **Service Quotas** too – an attacker launching instances hits one, and a raised quota is worth alerting on.

## ON THE EXAM

Unused Region, spike in EC2 spend, no alert – because nothing was watching that Region.

# What the whole thing looks like

- ◆ **Structure:** accounts by function, delegated administration, no workloads in the management account.
- ◆ **Ceilings:** SCPs on principals, RCPs on resources, declarative policies for what must not drift.
- ◆ **Evidence:** an org trail to a locked Log Archive, Config recording everywhere, findings in Security Tooling.
- ◆ **Identity:** federation over IAM users, permission sets by group, no root credentials in member accounts.
- ◆ **Practice:** tested runbooks, count-first deployment, restore tests, findings someone owns.

## ON THE EXAM

Every line is a module you have done. Domain 6 is the other five, arranged.

A company consolidates security into a single account holding the delegated administrator role for GuardDuty and Security Hub, the organization trail's destination bucket, and the Config aggregator. Analysts have administrator access to that account.

A reviewer objects that this design fails a requirement the company has written down: that evidence must survive the compromise of a security administrator.

### What should the company change?

- ☐ A Split into separate Security Tooling and Log Archive accounts, with restricted access to Log Archive
- ☐ B Keep one account and apply an SCP denying s3:DeleteObject on the trail bucket
- ☐ C Move the trail destination to the management account, which analysts cannot reach
- ☐ D Enable MFA delete on the trail bucket and require it for analyst sessions

### ◆ PAUSE AND DECIDE

## What should the company change?

- A

 Split into Security Tooling and Log Archive accounts  
*Correct. This is exactly what the SRA separation exists for – the people who read findings should not administer the evidence, enforced by an account boundary.*
- C

 Move the trail destination to the management account  
*Puts a workload in the account that runs no workloads, and the management account is exempt from SCPs and skipped by StackSets. The worst place for evidence.*
- B

 One account plus an SCP denying DeleteObject  
*A real improvement and still one boundary. An administrator in that account can alter the trail, the bucket policy or the Config aggregator – the SCP names one action.*
- D

 MFA delete plus MFA for analysts  
*Raises the cost of deletion and does not change who is authorised. A compromised administrator session may well carry MFA.*

### THE SIGNAL

The requirement names a compromised administrator. Only an account boundary puts the evidence outside their reach.

An organisation enables GuardDuty, Security Hub CSPM, Config, Macie and Detective, and administers all five from the management account because that is where the organisation is managed.

A security review flags this as an anti-pattern. The team argues that the management account is the most protected account they have, so it is the safest place.

### What is the strongest counter-argument?

- A The management account cannot enable organisation-wide security services
- B Security services perform better when run from a dedicated Region
- C SCPs do not constrain the management account and StackSets skip it, so controls that protect every other account do not protect this one
- D Delegated administration is mandatory for GuardDuty and Security Hub

### ◆ PAUSE AND DECIDE

## What is the strongest counter-argument?

- A

 It cannot enable org-wide services  
*False – it can, which is exactly why teams do this. The problem is not capability.*
- B

 Performance in a dedicated Region  
*Not a security argument, and not true. Region choice affects latency and data residency, not whether a service works.*
- C

 SCPs do not constrain it and StackSets skip it  
*Correct. The team's premise is inverted: the management account is the least constrained account, not the most protected. Modules 32 and 35 both established this.*
- D

 Delegated administration is mandatory  
*It is recommended, not mandatory. Overstating a best practice as a rule is a weaker argument than the true one.*

### THE SIGNAL

The team's premise is the error. 'Most protected' and 'least constrained' are opposites, and the management account is the second.

A finance analyst notices that a dormant account, used only for an archived project, has generated \$9,400 of EC2 charges this month in ap-southeast-2, a Region the company does not operate in. Last month's bill for that account was \$12.

The security team has received no findings for that account. GuardDuty is enabled organisation-wide.

**What is the most likely explanation, and what does the absence of findings tell you?**

- |                                                                                                        |                                                                                                              |
|--------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> A A billing error; raise a support case before investigating                  | <input type="checkbox"/> B Reserved Instance charges reallocated across the organisation                     |
| <input type="checkbox"/> C Legitimate use by another team; confirm with the account owner and close it | <input type="checkbox"/> D Probable cryptomining; check whether GuardDuty is actually enabled in that Region |

◆ PAUSE AND DECIDE

## What is the most likely explanation, and what does the absence of findings tell you?

A Billing error; raise a case first

*Treats a security signal as an accounting one. A support case takes days, and if this is an intrusion the meter runs the whole time.*

C Legitimate use; confirm and close

*Worth a phone call, and closing on the assumption of legitimacy is how this pattern goes unnoticed for months.*

B Reserved Instance reallocation

*RI charges shift between accounts and do not conjure EC2 usage in an unused Region for a dormant project.*

D Probable cryptomining; check GuardDuty coverage in that Region

*Correct. The cost pattern is textbook, and no findings from an unused Region usually means nothing is watching it – not that nothing happened.*

### THE SIGNAL

'Organisation-wide' does not mean every Region. The absence of findings is the second finding.

A CISO wants a structured, repeatable assessment of a specific production workload's security posture, producing risk-rated findings with an improvement plan that engineering can prioritise. She is not seeking a compliance score against a named standard.

The organisation already runs Security Hub CSPM with the AWS Foundational Security Best Practices standard.

### What should the organisation use?

- ☐ A Add the NIST 800-53 standard in Security Hub CSPM for broader coverage
- ☐ B A Well-Architected Tool review of that workload against the security pillar
- ☐ C A Config conformance pack scoped to the workload's resources
- ☐ D Trusted Advisor's security checks, exported for the engineering team

### ◆ PAUSE AND DECIDE

## What should the organisation use?

- A

 Add NIST 800-53 in Security Hub CSPM  
*More compliance scoring against a named standard, which is explicitly what she is not asking for. It also evaluates accounts rather than a workload.*
- B

 A Well-Architected review against the security pillar  
*Correct. It is workload-scoped, structured, repeatable, produces risk-rated findings and an improvement plan - and surfaces Trusted Advisor checks by pillar.*
- C

 A conformance pack for the workload  
*Config rules evaluate resource configuration continuously. Useful, and it produces compliance status rather than a prioritised improvement plan.*
- D

 Trusted Advisor security checks  
*Shallow and account-scoped by design. It flags an open security group without judging whether that is wrong for this workload.*

### THE SIGNAL

'A specific workload', 'risk-rated', 'improvement plan', 'not a compliance score' – four phrases, one tool.

# Six things to carry forward

- ◆ **Account structure is a control** – the only boundary not dependent on a policy being right.
- ◆ **Security Tooling and Log Archive are separate accounts** by design.
- ◆ **The management account is the least constrained account you have**, not the most protected.
- ◆ **Seven design principles**; 'keep people away from data' explains half this course.
- ◆ **Well-Architected reviews a workload. Security Hub CSPM scores an account.**
- ◆ **An unexplained compute bill is a security event**, and silence from an unused Region means nothing is watching.

## ON THE EXAM

That closes all six domains. Next: confusion pairs, exam mechanics, and what changed from C02.